

Security & Privacy Model

Threat Model, Identity Vault, Eriřim ve Veri Yařam Döngüsü

APPROVED BASELINE

Versiyon 1.2.0 • 28 Temmuz 2026

Kural ne diyor, vicdan ne söylüyor?

BELGE KONTROLÜ

Alan	Değer
Belge kimliği	KEFE-SEC-001
Sürüm	1.2.0
Tarih	28 Temmuz 2026
Durum	Approved Baseline
Belge sahibi	Security / Privacy
Normatif otorite	KEFE-MPD v1.2.0 + KEFE-ENG v0.4.0
Gözden geçirme ritmi	Her ana karar veya ilgili sistem değişikliği sonrası
Çelişki kuralı	En yeni onaylı KEFE Master Product Document kararı geçerlidir; belge manifesti ve durumlar için KEFE-GOV geçerlidir.

1. Güvenlik hedefleri

- Karar bütünlüğünü ve kullanıcı mahremiyetini korumak.
- Identity ile behavior verisini ayırmak.
- Admin ve provider compromise etkisini sınırlamak.
- Manipülasyon/scraping/automation'a dayanıklı olmak.
- Silme/export/consent haklarını uygulanabilir kılmak.

2. Veri sınıfları

Sınıf	Örnek	Kontrol
Restricted Identity	telefon, verification token	Identity Vault, field encryption, strict RBAC
Sensitive Preference	opt-in values, protected cohort signals	purpose limitation, thresholds
Pseudonymous Behavior	weigh, reason, exposure	actor_id, access controls
Aggregate	ResultSnapshot	cohort suppression
Public Content	published Case/source metadata	integrity + copyright/licensing policy
Security Telemetry	IP/risk/device signals	shortest necessary retention + limited access

3. Threat model

Tehdit	Örnek	Başlıca mitigasyon
Account abuse	farm, credential abuse	OTP/session controls, rate, device signals
Brigading	koordineli karar manipölasyonu	integrity, slow mode, delayed aggregate
API scraping	feed/results harvesting	rate, auth scope, WAF, abuse detection
Admin takeover	editor/security account compromise	MFA, least privilege, approval separation, audit
Data exfiltration	DB/log/provider leak	encryption, redaction, segmentation, egress controls
Prompt injection	malicious content/source	sandbox, allowlist, no privileged tools by default
Supply chain	dependency compromise	pinning, SBOM, scan, signed build where feasible
Insider abuse	unauthorized identity lookup	segregated roles, audited access

4. Identity Vault

- Core actor_id opaque ve pseudonymous'dır.
- Telefon/e-posta gibi identifier core decision tablolarına yazılmaz.
- Vault ayrı schema + encryption key + DB role; ölçek/risk gerekirse fiziksel DB ayrımı yapılabilir.
- Hash anonimlik kabul edilmez.

5. Authentication & session

- Provider-independent AuthPort; OTP sağlayıcısı değiştirilebilir.
- Short-lived access + secure refresh/session rotation yaklaşımı.
- Admin MFA zorunlu; privileged session hardening.
- Brute force/rate/abuse policy versioned.

6. Authorization

RBAC temelidir; riskli kaynaklar için ABAC/scoped claims eklenebilir. System Admin içerik kararı vermez; Security Admin identity/integrity erişimi ayrı tutulur. Researcher yalnız onaylı aggregate/study erişimi alır.

7. Encryption & secrets

- TLS in transit; at-rest encryption.
- Identity fields için application/field encryption.
- Secrets secret manager'da; rotation ve break-glass prosedürü.

- PII log redaction ve payload logging allowlist.

8. Privacy lifecycle

Aşama	Kural
Collect	Purpose + minimum necessary
Use	Consent/legal basis + access scope
Retain	Entity-specific policy/version
Export	Authenticated, scoped, machine-readable where feasible
Delete	User request + legal/audit exceptions explicit
Aggregate	Re-identification risk controlled
Archive	Operational need ends when policy says so

9. Backup & disaster recovery

- Encrypted backup, separate access domain.
- Restore tests scheduled; “backup var” tek başına yeterli değildir.
- RPO/RTO service tier bazında beta öncesi kilitlenir.
- Incident sırasında integrity of results için snapshot/event recovery procedure bulunur.

10. Secure SDLC

- SAST/DAST/dependency scan, SBOM, secret scan, IaC review.
- Auth/IDOR/rate-limit/admin RBAC/security regression CI gate.
- Threat model major feature öncesi güncellenir.
- Vulnerability disclosure/incident contact production launch öncesi tanımlanır.

11. Incident response

Detect → triage → contain → eradicate → recover → user/regulator notification assessment → postmortem → control update. Security incident product integrity veya published result’ı etkiliyorsa Trust/Editorial incident kaydıyla ilişkilendirilir.

Bağlayıcı gereksinimler

ID	Gereksinim	Üst kaynak
SEC-001	Identity Vault ile behavior core mantıksal erişim sınırıyla ayrılır.	MPD §38
SEC-002	Hash tek başına anonimlik kabul edilmez.	MPD §38

ID	Gereksinim	Üst kaynak
SEC-003	Kullanıcı export/delete/consent kontrolüne sahip olmalıdır.	MPD §38.3
SEC-004	Admin privileged access audit edilmelidir.	MPD §45
SEC-005	Provider secrets domain/config dosyasında tutulamaz.	MPD architecture principles

KARARLAR — V1.1.0

Karar 1 — Identity Vault physical boundary

Public beta itibarıyla Identity Vault ayrı PostgreSQL database mantıksal birimi, ayrı credentials ve ayrı encryption key ile çalışır; aynı managed cluster üzerinde olabilir. Core yalnız opaque actor_id görür.

Karar 2 — Initial DR targets

Production beta başlangıç hedefi RPO ≤ 5 dakika, RTO ≤ 60 dakika. En az aylık restore test ve ölçülmüş sonuç zorunludur; kritik risk/ölçek arttıkça hedef ADR ile sıkılaştırılır.

Karar 3 — Attribution retention

Raw marketing attribution varsayılan en fazla 90 gün; jurisdiction/consent daha kısa gerektirirse kısa süre uygulanır. Decision/Values/political signals attribution sistemine gönderilmez.

Değişiklik Geçmişi

Sürüm	Tarih	Değişiklik
1.0	27 Temmuz 2026	İlk onaylı baseline oluşturuldu.
1.1.0	27 Temmuz 2026	Identity Vault boundary, RPO/RTO hedefleri ve marketing attribution retention sınırı kesinleştirildi.
1.2.0	28 Temmuz 2026	Content/Admin milestone recovery from verified v3.2 + GitHub PR #40/#42 durable records; not byte-identical to lost original v3.3 artifact.

12. V1.2.0 - ADMIN SECURITY DOMAIN

- Consumer Actor credentials Admin credential olarak kabul edilemez. Admin identity ayrı immutable internal subject ile temsil edilir.
- Admin session opaque, immediately revocable ve MFA-assured'dır; raw session/CSRF secrets yerine digest persist edilir.
- Session assurance revocation, subject state, MFA, absolute expiry ve idle expiry kontrollerinden sonra activity refresh yapar; expired session kendini canlandıramaz.
- Same-session CSRF mutation ön koşuldur; cross-session CSRF reddedilir. Publish, withdraw ve access management high-impact commands recent step-up gerektirir.
- IdP/SSO seçimi authorization domain modeline gömülemez.

DEĞİŞİKLİK NOTU - V1.2.0

Content/Admin milestone recovery from verified v3.2 + GitHub PR #40/#42 durable records; not byte-identical to lost original v3.3 artifact.